

Information Security Policy Framework

A Comprehensive Template for Organizational Security Documentation

Version: 1.0Effective Date: _____

Document Owner: _____Classification: Internal

Contents

1	Introduction	4
1.1	Purpose	4
1.2	Scope	4
1.3	Definitions	4
2	Information Security Governance	5
2.1	Security Policy Hierarchy	5
2.2	Roles and Responsibilities	5
2.2.1	Board of Directors	5
2.2.2	Chief Information Security Officer (CISO)	5
2.2.3	Data Owners	5
2.2.4	System Administrators	5
2.2.5	All Users	5
3	Acceptable Use Policy (AUP)	6
3.1	Purpose	6
3.2	General Use	6
3.2.1	Acceptable Use	6
3.2.2	Unacceptable Use	6
3.3	Email and Communication	6
3.3.1	Acceptable Email Use	6
3.3.2	Unacceptable Email Use	7
3.4	Internet and Social Media	7
3.4.1	Acceptable Internet Use	7
3.4.2	Unacceptable Internet Use	7
3.4.3	Social Media Guidelines	7
4	Access Control Policy	8
4.1	Purpose	8
4.2	Access Control Principles	8
4.2.1	Least Privilege	8
4.2.2	Need-to-Know	8
4.2.3	Separation of Duties	8
4.3	User Lifecycle	8
4.3.1	Onboarding	8
4.3.2	Access Maintenance	8
4.3.3	Offboarding	8
4.4	Authentication Requirements	9
4.4.1	Password Policy	9
4.4.2	Multi-Factor Authentication (MFA)	9

4.5	Access Control Models	9
4.5.1	Role-Based Access Control (RBAC)	9
4.5.2	Mandatory Access Control (MAC)	9
5	Password and Account Security Policy	10
5.1	Purpose	10
5.2	Password Creation	10
5.3	Password Protection	10
5.4	Account Security	10
6	Remote Access Policy	11
6.1	Purpose	11
6.2	Acceptable Remote Access	11
6.3	Remote Access Requirements	11
6.4	Prohibited Remote Access Methods	11
7	Incident Response Policy	12
7.1	Purpose	12
7.2	Incident Response Phases	12
7.3	Reporting Requirements	12
8	Data Classification and Protection Policy	12
8.1	Purpose	12
8.2	Data Classification Levels	12
8.3	Protection Requirements	13
9	Policy Compliance and Enforcement	13
9.1	Compliance Monitoring	13
9.2	Non-Compliance Consequences	13
9.3	Exceptions	13
10	Policy Review and Updates	13

Document Control

Version	Changes Made
1.0	Initial document creation

Role	Responsibility
Document Owner	Overall ownership and maintenance of this policy
Security Team	Implementation and enforcement of security controls
IT Department	Technical implementation of security measures
All Employees	Compliance with policy requirements

1 Introduction

1.1 Purpose

The purpose of this Information Security Policy is to establish a framework for protecting [Organization Name]'s information assets from all threats, whether internal or external, deliberate or accidental. This policy defines the security requirements, responsibilities, and controls necessary to ensure the confidentiality, integrity, and availability (CIA) of organizational information.

1.2 Scope

This policy applies to:

- All employees, contractors, consultants, and temporary workers
- All information assets, including data, systems, networks, and devices
- All business processes and operations
- All third-party vendors and partners with access to organizational resources

1.3 Definitions

Term	Definition
Asset	Any data, device, or component that supports information-related activities
Confidentiality	Ensuring information is accessible only to authorized parties
Integrity	Ensuring information is accurate and complete
Availability	Ensuring information is accessible when needed
Incident	An event that threatens the security of information assets
Risk	The potential for loss or damage resulting from a threat exploiting a vulnerability
Vulnerability	A weakness in security controls that could be exploited
Threat	A potential cause of harm to information assets

2 Information Security Governance

2.1 Security Policy Hierarchy

Policy Hierarchy

1. **Policy:** High-level statements of management intent
2. **Standard:** Mandatory requirements for implementation
3. **Procedure:** Step-by-step instructions for performing tasks
4. **Guideline:** Recommended best practices

2.2 Roles and Responsibilities

2.2.1 Board of Directors

- Ultimate accountability for information security
- Approval of major security investments and policies
- Oversight of security governance and risk management

2.2.2 Chief Information Security Officer (CISO)

- Development and maintenance of security strategy
- Implementation and enforcement of security policies
- Management of security operations and incident response
- Reporting to executive management and board

2.2.3 Data Owners

- Classification and protection of their data
- Authorization of access to their data
- Periodic review of access permissions

2.2.4 System Administrators

- Technical implementation of security controls
- System patching and vulnerability management
- Monitoring and logging of system activity

2.2.5 All Users

- Compliance with all security policies and procedures
- Reporting of security incidents
- Protection of their credentials and access

3 Acceptable Use Policy (AUP)

3.1 Purpose

The Acceptable Use Policy defines the acceptable and unacceptable use of organizational information technology resources. This policy ensures that all users understand their responsibilities when using organizational systems and data.

3.2 General Use

3.2.1 Acceptable Use

- Using organizational resources for legitimate business purposes
- Accessing only authorized systems and data
- Protecting organizational information from unauthorized disclosure
- Following all applicable laws and regulations
- Using strong passwords and protecting authentication credentials
- Reporting security incidents immediately

3.2.2 Unacceptable Use

- Using organizational resources for illegal activities
- Accessing, downloading, or distributing inappropriate content
- Installing unauthorized software or hardware
- Sharing credentials or allowing others to use your account
- Bypassing security controls or monitoring systems
- Harassing, threatening, or discriminating against others
- Using organizational resources for personal gain
- Downloading copyrighted materials without authorization
- Engaging in activities that disrupt organizational operations

3.3 Email and Communication

3.3.1 Acceptable Email Use

- Using email for legitimate business communication
- Including appropriate disclaimers and signatures
- Exercising caution with attachments and links
- Marking sensitive information appropriately

3.3.2 Unacceptable Email Use

- Sending chain letters or hoaxes
- Sending unsolicited bulk email (spam)
- Sending inappropriate or offensive content
- Forwarding sensitive information without authorization
- Using personal email for business purposes

3.4 Internet and Social Media

3.4.1 Acceptable Internet Use

- Using the Internet for legitimate business research
- Accessing resources needed to perform job functions

3.4.2 Unacceptable Internet Use

- Visiting inappropriate or offensive websites
- Accessing personal social media during work hours (except breaks)
- Downloading unauthorized files or software
- Engaging in activities that consume excessive bandwidth

3.4.3 Social Media Guidelines

- Do not disclose confidential organizational information
- Do not represent personal opinions as organizational positions
- Do not engage with competitors inappropriately
- Do not post defamatory content about the organization

4 Access Control Policy

4.1 Purpose

The Access Control Policy defines the principles and procedures for controlling access to organizational information assets. This policy ensures that access is granted based on the principles of least privilege and need-to-know.

4.2 Access Control Principles

4.2.1 Least Privilege

Users shall be granted the minimum level of access necessary to perform their job functions. Access permissions shall be reviewed regularly and adjusted as needed.

4.2.2 Need-to-Know

Users shall have access only to information they need to perform their job functions, regardless of their clearance level.

4.2.3 Separation of Duties

Critical tasks shall be divided among multiple individuals to prevent fraud and errors.

4.3 User Lifecycle

4.3.1 Onboarding

1. Request for access (completed by manager)
2. Approval (completed by data owner or manager)
3. Provisioning (completed by IT or security team)
4. Notification (user is informed of credentials)
5. Training (user completes security awareness training)

4.3.2 Access Maintenance

1. Periodic review of access permissions (quarterly)
2. Update of access when job roles change
3. Removal of access when no longer needed

4.3.3 Offboarding

1. Notification of employee departure (HR)
2. Immediate revocation of all access
3. Recovery of organizational devices and assets
4. Deletion of user account

4.4 Authentication Requirements

4.4.1 Password Policy

Requirement	Specification
Minimum Length	12 characters
Complexity	Must include uppercase, lowercase, numbers, and special characters
Password History	Last 12 passwords cannot be reused
Maximum Age	90 days (30 days for privileged accounts)
Minimum Age	1 day
Account Lockout	After 5 failed attempts for 30 minutes

4.4.2 Multi-Factor Authentication (MFA)

MFA shall be required for:

- Remote access (VPN, VDI)
- Administrative and privileged accounts
- Access to sensitive data and systems
- Financial and HR systems

4.5 Access Control Models

4.5.1 Role-Based Access Control (RBAC)

Access permissions shall be assigned based on roles rather than individual users. Users are assigned to roles, and roles inherit permissions.

Sample Roles

- **General User:** Basic access to email, files, and applications
- **Power User:** Enhanced access to department-specific resources
- **Administrator:** Full system administration privileges
- **Data Owner:** Control over specific data sets
- **Auditor:** Read-only access for compliance purposes

4.5.2 Mandatory Access Control (MAC)

For highly sensitive data, mandatory access control shall be implemented based on security classifications.

5 Password and Account Security Policy

5.1 Purpose

The Password and Account Security Policy establishes requirements for creating, managing, and protecting user accounts and credentials.

5.2 Password Creation

1. Passwords shall be at least 12 characters long
2. Passwords shall include a mix of uppercase, lowercase, numbers, and special characters
3. Passwords shall not contain dictionary words or personal information
4. Passwords shall not be the same as previously used passwords
5. Passwords shall be unique to each system

5.3 Password Protection

- Passwords shall not be shared with anyone
- Passwords shall not be written down or stored insecurely
- Passwords shall not be transmitted in clear text
- Password managers shall be used to store complex passwords
- Default passwords shall be changed immediately

5.4 Account Security

- Accounts shall be unique to each user (no shared accounts)
- Accounts shall be disabled after 30 days of inactivity
- Accounts shall be locked after 5 failed login attempts
- Accounts shall be reviewed quarterly for appropriateness
- Privileged accounts shall be subject to additional controls

6 Remote Access Policy

6.1 Purpose

The Remote Access Policy defines the requirements for accessing organizational resources from outside the physical network perimeter.

6.2 Acceptable Remote Access

- VPN access using approved VPN solutions
- Secure desktop (VDI) access
- Web-based access to email and approved applications
- Remote support using approved tools

6.3 Remote Access Requirements

1. Multi-factor authentication shall be required for all remote access
2. Endpoint devices shall have up-to-date antivirus and security patches
3. Endpoint devices shall have full disk encryption enabled
4. Remote sessions shall be terminated after 15 minutes of inactivity
5. All remote access shall be logged and monitored

6.4 Prohibited Remote Access Methods

- Unsecured remote desktop (RDP)
- Unencrypted file transfers (FTP, Telnet)
- Unapproved remote access tools
- Use of personal devices without approved MDM

7 Incident Response Policy

7.1 Purpose

The Incident Response Policy defines the procedures for detecting, responding to, and recovering from security incidents.

7.2 Incident Response Phases

Incident Response Lifecycle

1. **Preparation:** Planning, training, and tool deployment

2. **Detection & Analysis:** Identifying and analyzing potential incidents

3. **Containment:** Limiting the scope and impact of the incident

4. **Eradication:** Removing the root cause of the incident

5. **Recovery:** Restoring affected systems to normal operation

6. **Post-Incident Activity:** Lessons learned and improvements

7.3 Reporting Requirements

All security incidents shall be reported immediately to the security team. The following information shall be collected:

- Date and time of discovery
- Description of the incident
- Systems and data affected
- Potential impact and scope
- Actions taken so far

8 Data Classification and Protection Policy

8.1 Purpose

The Data Classification and Protection Policy defines how organizational data shall be classified and protected based on its sensitivity and importance.

8.2 Data Classification Levels

Classification	Description	Examples
Public	Information that can be freely shared	Marketing materials, annual reports
Internal Use Only	Information for internal use only	Internal memos, meeting notes
Confidential	Sensitive business information	Financial data, trade secrets
Restricted	Highly sensitive information	PII, PHI, regulated data

8.3 Protection Requirements

Classification	Protection Requirements
Public	No special protection required
Internal Use Only	Basic access controls, marked as internal
Confidential	Strong access controls, encryption in transit and at rest
Restricted	Strongest access controls, encryption, logging, approval required

9 Policy Compliance and Enforcement

9.1 Compliance Monitoring

- Regular security audits (quarterly)
- Automated compliance checks
- Periodic access reviews
- Incident tracking and reporting

9.2 Non-Compliance Consequences

Violations of this policy may result in:

- Disciplinary action (up to and including termination)
- Loss of system access
- Personal liability for damages
- Legal action (for criminal violations)

9.3 Exceptions

Exceptions to this policy must be:

1. Requested in writing
2. Approved by the CISO or designee
3. Documented with justification
4. Reviewed periodically

10 Policy Review and Updates

This policy shall be reviewed and updated:

- Annually (minimum)
- When significant changes occur in the threat landscape
- When new regulations or compliance requirements are introduced
- Following significant security incidents

Acknowledgement

I have read, understand, and agree to comply with the Information Security Policy of [Organization Name].

Signature:	Date: _____

Name: _____	Title: _____